

Cyber Threat Intelligence

Executive Briefing

Report Date: June 30, 2026

Generated: 2026-06-30 14:38 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
0	11	8	1	20

2. Executive Summary

As of June 30, 2026, the organization has completed a rigorous assessment of 20 identified vulnerabilities, consisting of 0 Critical, 11 High, 8 Medium, and 1 Low severity findings. The current security posture remains challenged by high-complexity exploit vectors, necessitating immediate mitigation to maintain baseline integrity. CVE-2026-55698, identified as Lockfile Resolution Hijacking in pnpm, represents the primary threat due to its potential to facilitate unauthorized code execution through environment manipulation. Management is advised to adopt an aggressive remediation posture, prioritizing the immediate patching of all High-severity exposures to prevent systemic exploitation. The overall risk exposure is currently categorized as Elevated, requiring prompt intervention by technical stakeholders.

3. Critical Action List

- Execute an immediate patch rollout for CVE-2026-55698 within 24 hours to neutralize the lockfile resolution hijacking threat.
- Remediate the arbitrary file write vulnerability in Gonic (CVE-2026-49340) through authorized configuration updates within 48 hours.
- Initiate an emergency configuration hardening sequence for OpenAM instances to address CVE-2026-47426 (JWKS Cache Impersonation) within 72 hours.
- Deploy authenticated access controls and script execution patches for CVE-2026-47424 (Groovy Sandbox Escape) within 72 hours.
- Restrict and reconfigure pnpm dependency resolution mechanisms to mitigate CVE-2026-55697 within 96 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-55698	Lockfile Resolution Hijacking in ...	8.8	High	89/100	CWE-345

CVE-2026-49340	Arbitrary File Write in Gonic	8.1	High	83/100	CWE-22
CVE-2026-47426	JWKS Cache Impersonation in OpenAM	8.8	High	79/100	CWE-287
CVE-2026-47424	Authenticated RCE via Groovy Sand...	8.8	High	79/100	CWE-693
CVE-2026-55697	Config Injection via pnpm Dependence...	7.5	High	78/100	CWE-78
CVE-2026-55487	Manifest Spoofing in pnpm	7.5	High	78/100	CWE-346
CVE-2026-55700	Directory Traversal in pnpm Downl...	7.1	High	74/100	CWE-22
CVE-2026-49338	Playlist IDOR in Subsonic API	7.1	High	74/100	CWE-285
CVE-2026-49339	Playlist Path Traversal in Gonic	7.1	High	74/100	CWE-22
CVE-2026-48717	OAuth Authorization Bypass in Ope...	8.1	High	73/100	CWE-285
CVE-2026-53523	Host Header Injection in Nezha OA...	6.8	Medium	71/100	CWE-601
CVE-2026-55699	Unsafe Deletion of PNPM_HOME	6.5	Medium	69/100	CWE-22
CVE-2026-53522	Resource Exhaustion in Nezha WebS...	6.5	Medium	69/100	CWE-770
CVE-2026-44840	DQL Injection in Dgraph GraphQL A...	7.5	High	68/100	CWE-943
CVE-2026-53465	Heap Buffer Over-Write in ImageMa...	6.2	Medium	66/100	CWE-122
CVE-2026-55180	Secret Exposure in pnpm Registry ...	6.5	Medium	59/100	CWE-200
CVE-2026-54243	CSV Formula Injection in Statamic	6.1	Medium	55/100	CWE-1236
CVE-2026-53464	Memory Leak in ImageMagick Parser	4.0	Medium	46/100	CWE-401
CVE-2026-54242	SSRF in Statamic Glide Image Proc...	4.9	Medium	44/100	CWE-367
CVE-2026-54244	Unauthorized Preview Content Acce...	3.5	Low	27/100	CWE-863

5. Detailed Vulnerability Findings

CVE-2026-55698

Finding: Lockfile Resolution Hijacking in pnpm

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 89/100 | CWE: CWE-345

MITRE ATT&CK: T1195, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The pnpm project environment lockfile mechanism can be exploited to short-circuit resolution and force the execution of arbitrary bytes provided in the lockfile. This enables a supply chain attack where malicious code is executed during the build process.

Proof of Concept (PoC):

An attacker introduces a modified lockfile into a repository. When a user runs pnpm install, the tool uses the tampered

lockfile to resolve dependencies and executes arbitrary code stored within the malicious bytes, compromising the developer environment.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55698>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55698>

CVE-2026-49340

Finding: Arbitrary File Write in Gonic

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 83/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Gonic contains an arbitrary file write vulnerability within its createPlaylist functionality. An authenticated user can write playlist content to an attacker-controlled path on the host system, potentially overwriting configuration or system files.

Proof of Concept (PoC):

An authenticated user creates a playlist with a maliciously crafted name or file path attribute. When the application writes the M3U data, it fails to constrain the file operation to the target directory, allowing file writes to arbitrary locations on the filesystem.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49340>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49340>

CVE-2026-47426

Finding: JWKS Cache Impersonation in OpenAM

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-287

MITRE ATT&CK: T1550, T1555

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

OpenAM is vulnerable to OAuth client impersonation due to an improperly secured JWKS resolver cache. This allows an attacker to manipulate cached public keys, resulting in successful token forgery and unauthorized identity assumption.

Proof of Concept (PoC):

An attacker triggers a cache refresh mechanism for the JWKS resolver with a malicious key set. Once the cache is poisoned, the server validates subsequent forged JWTs against the attacker's key, granting the attacker access as an

arbitrary user.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-47426>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-47426>

CVE-2026-47424

Finding: Authenticated RCE via Groovy Sandbox Escape

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-693

MITRE ATT&CK: T1059, T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

OpenAM features an authenticated remote code execution vulnerability involving a flaw in the Groovy script sandbox. An authenticated attacker can escape the restricted execution environment to execute arbitrary system commands on the underlying host.

Proof of Concept (PoC):

An authenticated user with permission to run scripts supplies a specifically crafted payload targeting the Groovy sandbox. The payload bypasses security restrictions and executes commands under the context of the application server service account.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-47424>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-47424>

CVE-2026-55697

Finding: Config Injection via pnpm Dependencies

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-78

MITRE ATT&CK: T1059, T1195

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm allows repository-controlled configDependencies to select a paquet native install engine, which can lead to command execution during dependency resolution. This allows attackers to run unauthorized shell commands on the developer's system.

Proof of Concept (PoC):

An attacker creates a malicious package that defines a custom configuration dependency targeting the paquet engine.

When a developer installs the package, the engine executes unintended shell commands specified by the attacker.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55697>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55697>

CVE-2026-55487

Finding: Manifest Spoofing in pnpm

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-346

MITRE ATT&CK: T1195, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm fails to properly validate manifest identity, allowing an attacker to spoof package manifests. This satisfies security checks like 'allowBuilds', enabling the execution of arbitrary lifecycle scripts within the victim's environment.

Proof of Concept (PoC):

An attacker publishes a package with a falsified manifest that mimics a trusted package. pnpm fails to verify the source, executes the malicious lifecycle script embedded in the manifest, and compromises the installation environment.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55487>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55487>

CVE-2026-55700

Finding: Directory Traversal in pnpm Downloads

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	High

Description:

pnpm is vulnerable to a path traversal flaw during the 'stage download' process. By crafting a manifest name or version string containing directory traversal sequences, an attacker can overwrite arbitrary files outside the designated target directory.

Proof of Concept (PoC):

An attacker publishes a malicious package with a specially crafted version string to a registry. When a victim installs this package, the pnpm download process evaluates the malicious string, causing the tool to write files to unintended sensitive system directories.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55700>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55700>

CVE-2026-49338

Finding: Playlist IDOR in Subsonic API

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-285

MITRE ATT&CK: T1565, T1040

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

The Subsonic API suffers from an Insecure Direct Object Reference (IDOR) vulnerability, allowing any authenticated user to read or delete playlists belonging to other users. This impacts the confidentiality and integrity of user data.

Proof of Concept (PoC):

An authenticated user captures an API request for their own playlist and modifies the 'id' parameter to reference a target playlist they do not own. The server fails to enforce ownership checks, executing the request on the victim's data.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49338>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49338>

CVE-2026-49339

Finding: Playlist Path Traversal in Gonic

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Gonic is vulnerable to path traversal within the playlist 'id' parameter, which bypasses ownership checks. This enables any authenticated user to perform unauthorized read or delete operations on playlists belonging to other users.

Proof of Concept (PoC):

An attacker sends a request to the playlist endpoint with a modified 'id' parameter containing directory traversal sequences (e.g., ../). The backend service fails to sanitize the path, allowing the user to access files or playlists outside their permitted scope.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49339>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49339>

CVE-2026-48717

Finding: OAuth Authorization Bypass in OpenAM

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 73/100 | CWE: CWE-285

MITRE ATT&CK: T1185, T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

OpenAM exhibits an authorization bypass vulnerability within its OAuth implementation related to PKCE challenge validation. An attacker could potentially bypass security controls during the authentication handshake, leading to unauthorized session establishment.

Proof of Concept (PoC):

An attacker initiates an OAuth flow and provides an invalid or absent PKCE challenge. Due to flawed validation logic in OpenAM, the service fails to reject the request, allowing the attacker to proceed with a forged authorization state.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48717>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48717>

CVE-2026-53523

Finding: Host Header Injection in Nezha OAuth

CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 71/100 | CWE: CWE-601

MITRE ATT&CK: T1213, T1566

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Nezha Monitoring is susceptible to Host Header Injection within its OAuth2 redirect URL implementation. An attacker can manipulate the redirect destination, enabling open redirection or credential interception attacks.

Proof of Concept (PoC):

An attacker sends a crafted OAuth request containing a malicious Host header. The application incorrectly incorporates this header into the redirect URL, causing the user to be redirected to an attacker-controlled site upon authentication completion.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53523>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53523>

CVE-2026-55699

Finding: Unsafe Deletion of PNPM_HOME

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-22

MITRE ATT&CK: T1485, T1070

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The global remove functionality in pnpm utilizes a reserved bin name that results in the deletion of the entire PNPM_HOME directory. This leads to an unintended denial-of-service condition affecting all installed global packages.

Proof of Concept (PoC):

A local attacker executes the pnpm global remove command on a package with a specific bin name. The system processes the request by recursively removing the contents of the global pnpm home directory, effectively breaking all related application environments.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55699>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55699>

CVE-2026-53522

Finding: Resource Exhaustion in Nezha WebSockets

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Nezha Monitoring contains an vulnerability where unbounded WebSocket streams allow a resource exhaustion denial-of-service attack. Uncontrolled streams consume excessive memory and CPU, leading to service degradation.

Proof of Concept (PoC):

An attacker opens multiple concurrent WebSocket connections to the monitoring service without closing them. The application fails to limit these streams, causing a build-up of resources until the service becomes unresponsive to legitimate users.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53522>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53522>

CVE-2026-44840

Finding: DQL Injection in Dgraph GraphQL API

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-943

MITRE ATT&CK: T1190, T1505

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Dgraph is susceptible to DQL injection via the checkUserPassword GraphQL query component. An attacker can supply maliciously crafted input to the query parameter to manipulate backend database logic, potentially leading to unauthorized data access or credential bypass.

Proof of Concept (PoC):

An attacker sends a crafted GraphQL query to the checkUserPassword endpoint containing DQL syntax that deviates from expected schema structure. The database engine executes the injected logic, allowing the attacker to retrieve sensitive user account data.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-44840>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-44840>

CVE-2026-53465

Finding: Heap Buffer Over-Write in ImageMagick

CVSS v3.1 Score: 6.2 | Severity: Medium | Urgency Score: 66/100 | CWE: CWE-122

MITRE ATT&CK: T1203, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

ImageMagick is vulnerable to a heap buffer overflow in the SF3 encoder when processing multi-frame images. An attacker can craft a malicious image that triggers this overflow, leading to arbitrary code execution or process crashes.

Proof of Concept (PoC):

An attacker delivers a specially crafted multi-frame SF3 image file to a user. When ImageMagick attempts to parse or encode this image, the heap buffer overflow occurs, allowing the attacker to overwrite memory and potentially control execution flow.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53465>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53465>

CVE-2026-55180

Finding: Secret Exposure in pnpm Registry Requests

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-200

MITRE ATT&CK: T1552, T1071

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

pnpm configuration can be manipulated to expand environment secrets into registry requests before scripts run. This allows an attacker to intercept and harvest sensitive environment credentials via malicious registry requests.

Proof of Concept (PoC):

An attacker provides a project configuration that includes placeholders for sensitive environmental secrets in a registry request URL. When pnpm executes, it expands these secrets in plaintext, sending them to the attacker's server.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55180>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55180>

CVE-2026-54243

Finding: CSV Formula Injection in Statamic

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-1236

MITRE ATT&CK: T1059, T1566

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic CMS is vulnerable to CSV formula injection when exporting form submissions. Maliciously crafted data entries can trigger spreadsheet software to execute external commands upon opening the exported file.

Proof of Concept (PoC):

An attacker submits a form entry containing a string starting with '=' (e.g., '=cmd|'/C calc!'A1'). When an administrator exports these submissions to CSV and opens them in Excel, the malicious formula executes, potentially compromising the admin's machine.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54243>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54243>

CVE-2026-53464

Finding: Memory Leak in ImageMagick Parser**CVSS v3.1 Score: 4.0 | Severity: Medium | Urgency Score: 46/100 | CWE: CWE-401**

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

ImageMagick suffers from a memory leak in its wand option parser when provided with invalid input arguments. Repeated exploitation of this vulnerability could lead to a denial-of-service state due to resource exhaustion.

Proof of Concept (PoC):

An attacker sends a flood of requests to an application using ImageMagick, providing invalid arguments to the wand option parser. Each request causes the application to leak memory, eventually exhausting system resources and crashing the service.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53464>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53464>**CVE-2026-54242****Finding: SSRF in Statamic Glide Image Processor****CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 44/100 | CWE: CWE-367**

MITRE ATT&CK: T1190, T1071

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic's Glide component is vulnerable to Server-Side Request Forgery (SSRF) through DNS rebinding attacks. An attacker can force the server to make requests to internal network services that should otherwise be unreachable.

Proof of Concept (PoC):

An attacker controls a domain name and triggers a DNS rebinding scenario against the Glide image processor. By forcing the server to resolve the domain to a loopback or internal address, the attacker can make the server perform requests to internal resources.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54242>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54242>**CVE-2026-54244****Finding: Unauthorized Preview Content Access in Statamic**

CVSS v3.1 Score: 3.5 | Severity: Low | Urgency Score: 27/100 | CWE: CWE-863

MITRE ATT&CK: T1068, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Statamic CMS has an authorization flaw where view-only users can submit Live Preview content that is strictly reserved for editors. This unauthorized interaction compromises the integrity of the publishing workflow.

Proof of Concept (PoC):

A user with low-level privileges attempts to access or interact with the Live Preview feature. The server fails to validate the user's role against the restricted action, allowing the user to modify or submit content that should be inaccessible.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54244>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54244>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>